AI-assisted security review

Review date: 2026-09-14. Scope: this repository's TON escrow/test fixtures, Compact bridge/pool, TypeScript SDK, observers, relay scripts, journal and deployment workflow. This is the implementing agent's review, not an independent audit or a declaration of production safety. Source and key fingerprints are recorded in validation evidence. Outcome: suitable for continued isolated synthetic-asset testing; real-value/public production clearance is withheld.

Reviewed controls

TON deposits authenticate the escrow's derived wallet and validate the 32-byte forward payload. Normal releases require two different committee indices and Ed25519 signatures binding escrow, domain, ID, amount and recipient. Replay records and pending request accounting prevent duplicate normal release. The authenticated immediate bounce restores backing; test coverage also exercises malformed deposits and separately authorized recovery.

Midnight claim authorization binds the deployment address, route domain, receipt, asset, amount and recipient. Two distinct Schnorr signers, replay membership and per-asset circulating caps are checked. Redemption receives actual unshielded tokens and records a commitment; retired tokens remain locked and cannot be spent by AMM operations beyond tracked reserves. Pool operations bound outputs, shares and division witnesses; minimum outputs and secret-authorized withdrawals are enforced.

The journal persists exact signed bytes before broadcast and uses compare-and-set transitions. Ambiguous sends stay ambiguous and are reconciled by exact transaction identifier. Signer tools fetch chain state themselves instead of signing arbitrary supplied receipts. Reverse verification pins the verifier set and maintenance authority. Test seeds, committee scalars, maintenance keys and LP secrets are ignored and created with restricted file modes. The wallet library's seed logger is silenced.

Open findings and trust boundaries

HIGH - Committee trust. Two compromised or colluding members can mint unbacked tokens or authorize withdrawals/recovery. RPC snapshots are trusted observations, not light-client proofs. The local demo holds every key in one process. Required disposition: explicitly accept this POC trust model; use genuinely independent operators and infrastructure before an externally used deployment, or redesign verification.

HIGH - Midnight maintenance authority. The deployed contract has a maintenance key capable of changing verifier rules. The key is persisted before deployment and observers pin its authority, but historical malicious changes cannot be excluded by a current snapshot. Required disposition: independently review governance/custody or test and execute permanent authority removal before valuable assets. Do not represent this deployment as immutable.

HIGH - Custom Schnorr transcript. The stable Compact compiler lacks the initially considered newer signature helpers. The implementation uses Jubjub and a 248-bit challenge derived from transientHash. Runtime tests show matching off-chain/on-chain transcripts and domain binding, but this is not a cryptographic proof of security or an independently audited implementation. Required disposition: specialist review of subgroup validation, Fiat-Shamir encoding, challenge conversion, nonce generation and circuit soundness.

HIGH - Asynchronous jetton recovery. A later failed recipient transfer can return tokens without a direct escrow bounce; malformed transfers can create unregistered inventory. The separate two-signature recovery opcode has no on-chain proof of surplus and can be abused by quorum. Required disposition: full trace reconciliation and a signed recovery policy that excludes pending/claimable deposits and collateral. Never infer safety from wallet balance minus locked alone.

MEDIUM - Token compatibility. The supplied minter/wallet are restricted fixtures using a classic wallet data layout, not production-complete TEP-74 implementations or official USD1. Required disposition: audited asset-specific adapters, issuer authorization and real wallet lifecycle integration tests for any production token.

MEDIUM - Operational completeness. A CLI/manual-run POC does not provide a hosted watcher, automated TON trace finalizer, metrics, paging, key rotation, disaster recovery or a service SLA. Required disposition: assign an operator and implement/test these services against the accepted networks. Gas/DUST shortages and signer outages affect liveness. Fixed committee migration requires a new backed route.

MEDIUM - Privacy and starter scope. Transfers and unshielded balances are public and linkable to TON. The starter's notes are local-memory objects with a salted commitment, not a deployed private-note protocol. Required disposition: do not claim anonymity, durable storage, Telegram authentication or on-chain notes privacy. Agree the scaffold's acceptance scope and add an audited privacy interaction if required.

MEDIUM - Economic and arithmetic acceptance. LP reserves are distinct from backing; initial price is selected by the first LP, paired excess donations are allowed, and minimum amounts depend on caller quotes. Tests cover representative invariants and bounded arithmetic but not exhaustive formal verification or economic adversaries. Required disposition: explicit decimals/ratio, meaningful slippage limits, property-based boundary testing and economic review before real liquidity. No dollar peg or LP principal guarantee exists.

LOW - Packaging and independent reproduction. A clean directory on the author's machine is useful evidence but is not the required third-party independent-machine build. Required disposition: another developer follows the delivered instructions and supplies their own evidence. Root Node SDK browser bundling and browser wallet adapters are unverified.

Test interpretation

Passing runtime tests establish execution behavior for the supplied inputs. TON Sandbox executes TVM but does not establish public-network finality. Local Midnight proofs establish proof-generation/ledger compatibility for the exercised transactions. None of these establishes safety under all adversarial inputs, an external audit pass, a public two-chain release, or contractual acceptance. See validation.md for actual terminal results and proof transaction evidence; do not infer completion from the presence of a demo script.

Recommended release decision

Keep the release test-only. Complete the proof-backed exercise, independent reproduction, benchmark targets, trace-recovery drills and agreed synthetic-asset demonstration. Deliver this review with its open findings rather than labeling it a passing production audit. Obtain the required reviewer/Foundation acceptance and publish the approved PDF's IPFS reference through the SDK documentation only after reviewing the exact public artifact. No upload or public link has been created by this review.